

SECURITY ASSESSMENT REPORT

Vulnbank Mobile Lending & Payments Platform

Web & API Penetration Test

Client	Vulnbank Ltd. (Nairobi, Kenya)
Engagement	External Web & API Penetration Test
Target	https://vulnbank.org/
Classification	CONFIDENTIAL
Report version	1.0 (Final)
Report date	6 October 2026
Testing window	29 September – 3 October 2026
Prepared by	AfricaHackon Assessment Squad
Authors	N. Ngumo (Lead), Squad Members

Distribution notice. This document contains confidential security findings about Vulnbank systems. It is intended solely for authorised Vulnbank personnel and the assessment team. All sensitive values (credentials, tokens, customer data, GPS coordinates, one-time passwords) have been redacted. Unauthorised disclosure, copying or distribution is prohibited.

Document Control

CONFIDENTIAL — Vulnbank Ltd. Security Assessment · Do not distribute

Version history

Version	Date	Author	Description
0.1	3 Oct 2026	Assessment Squad	Initial draft — findings captured
0.9	5 Oct 2026	Assessment Squad	Internal QA and peer review
1.0	6 Oct 2026	Assessment Squad	Final release to client

Classification handling

This report is classified **CONFIDENTIAL**. Store encrypted at rest, transmit only over encrypted channels, and restrict access to named recipients on the Vulnbank side and the assessment team.

Contact

Role	Name	Responsibility
Engagement lead	N. Ngumo	Technical findings, retest coordination
Client sponsor	Vulnbank CISO	Remediation ownership

CVSS scores in this report use CVSS v3.1. Weakness references use CWE; category references use the OWASP API Security Top 10 (2023) and OWASP Web Security Testing Guide.

Executive Summary

CONFIDENTIAL — Vulnbank Ltd. Security Assessment · Do not distribute

Vulnbank engaged the AfricaHackon Assessment Squad to perform an external penetration test of its mobile lending and payments platform, focusing on the public web application and its supporting REST APIs. The objective was to determine whether an authenticated customer — or an attacker holding a single ordinary account — could access other customers' data, manipulate financial balances, or reach internal systems.

The assessment identified **three confirmed vulnerabilities**, including **one Critical** and **one High** severity issue. Collectively they show that the platform's API enforces authentication (proving *who* a user is) but repeatedly fails at authorisation (enforcing *what* that user is allowed to do). For a licensed fintech this is a material risk to customer privacy, financial integrity, and regulatory standing.

Key findings in business terms

- **Any customer can read any other customer's personal and vehicle-tracking data (Critical).** By changing an identifier in an API request, an ordinary account retrieved another customer's full name, email address and live GPS location. This is a direct breach of customer privacy and Kenya's Data Protection Act, 2019.
- **Customers can create their own discount coupons and inflate their wallet balance (High).** An authorisation gap on a coupon endpoint let a standard user mint an arbitrary coupon and redeem it, increasing their account credit at will — direct financial loss and fraud exposure.
- **A server-side request forgery flaw lets the platform be turned against its own internal network (Medium).** A customer-controlled URL caused Vulnbank servers to call an internal-only service, exposing internal mail content including one-time passwords.

Overall risk rating: High

The combination of broken object-level authorisation and a business-logic flaw affecting account balances means the platform cannot currently guarantee the confidentiality of customer data or the integrity of financial transactions. The Critical and High findings are each independently exploitable by a single low-privileged account with no special tooling, and would be attractive to both opportunistic fraudsters and automated attackers.

Top recommendations

1. Enforce server-side object-level authorisation on every endpoint that accepts an identifier — confirm the authenticated user owns the requested object before returning or modifying it.
2. Move all balance-affecting operations (coupons, credits, orders) to trusted server-side logic with strict role checks; never trust client-supplied amounts or coupon definitions.
3. Block server-side request forgery by validating and allow-listing outbound URLs and isolating internal services from user-reachable requests.

None of the three findings required source code, insider access, or privilege escalation beyond a normal customer login. All are fixable with well-understood controls, prioritised in the roadmap at the end of this report.

Scope & Methodology

CONFIDENTIAL — Vulnbank Ltd. Security Assessment · Do not distribute

In scope

Asset	Description
https://vulnbank.org/	Public web application (customer portal)
/identity/api/*	Authentication, profile and vehicle services
/community/api/*	Community, coupon and forum services
/workshop/api/*	Shop, coupon redemption and mechanic/merchant services

Out of scope

- Denial-of-service and volumetric testing
- Social engineering and physical security
- Third-party payment processors and upstream providers
- Underlying cloud infrastructure and host operating systems

Rules of engagement

Testing was authorised, time-boxed, and conducted against a non-production assessment environment provisioned by Vulnbank. Two standard customer accounts were created for the test ("attacker" and "victim") so that cross-account access could be demonstrated safely without touching real customer data. No destructive actions were performed and no live customer records were accessed.

Approach

The assessment followed the OWASP Web Security Testing Guide and the OWASP API Security Top 10 (2023), using an authenticated grey-box methodology:

1. **Reconnaissance & mapping** — enumerated API endpoints and documented expected behaviour.
2. **Authentication baseline** — registered two independent accounts and captured their session tokens.
3. **Authorisation testing** — replayed each account's requests against the other account's objects to detect broken access control.
4. **Business-logic testing** — probed balance- and coupon-affecting workflows for integrity flaws.
5. **Server-side request testing** — tested endpoints accepting URLs for request forgery.
6. **Evidence capture & verification** — recorded responses, then re-verified each finding to eliminate false positives.

Severity model

Each finding is scored with CVSS v3.1. The qualitative rating maps to the CVSS base score as follows:

Rating	CVSS v3.1 base score
CRITICAL	9.0 – 10.0

HIGH	7.0 – 8.9
MEDIUM	CONFIDENTIAL – Vulnbank Ltd. Security Assessment · Do not distribute 4.0 – 6.9
LOW	0.1 – 3.9

Evidence handling & redaction

All evidence in this report is redacted. Session tokens, customer email addresses, GPS coordinates, one-time passwords and internal hostnames are masked. Redacted values are shown as [REDACTED] or partially masked (for example a***@example.com). Full unredacted evidence is retained securely by the assessment team and available to Vulnbank on request through a secure channel.

Findings Summary

CONFIDENTIAL — Vulnbank Ltd. Security Assessment · Do not distribute

Three vulnerabilities were confirmed during the engagement. The table below lists them in priority order. Detailed write-ups follow.

ID	Finding	Severity	CVSS v3.1	CWE	OWASP API Top 10 (2023)	Status
VB-01	Broken Object Level Authorisation exposes customer PII and live vehicle location	CRITICAL	9.1	CWE-639	API1:2023 — BOLA	Open
VB-02	Broken function-level authorisation lets customers mint coupons and inflate wallet balance	HIGH	8.3	CWE-840 / CWE-915	API5:2023 — BFLA	Open
VB-03	Server-Side Request Forgery reaches internal services and leaks OTP email	MEDIUM	6.5	CWE-918	API7:2023 — SSRF	Open

Severity	Count
CRITICAL	1
HIGH	1
MEDIUM	1
LOW	0

Status "Open" indicates the finding was confirmed during testing and awaits remediation and retest. CVSS vectors and full justification appear in each finding below.

Detailed Findings

CONFIDENTIAL — Vulnbank Ltd. Security Assessment · Do not distribute

VB-01 — Broken Object Level Authorisation exposes customer PII and live vehicle location **CRITICAL**

Severity	Critical (CVSS v3.1 base 9.1)
CVSS vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N
CWE	CWE-639: Authorization Bypass Through User-Controlled Key
OWASP	API1:2023 — Broken Object Level Authorization
Affected asset	GET /identity/api/v2/vehicle/{vehicleId}/location
Status	Open — confirmed

Description

The vehicle-location endpoint returns the record matching the `vehicleId` supplied in the URL without verifying that the requesting user owns that vehicle. Because the endpoint authenticates the caller but never authorises the *object* being requested, any logged-in customer can retrieve any other customer's vehicle record simply by substituting a different identifier. The response discloses the owner's full name, email address and real-time GPS coordinates.

Impact

This is a mass-disclosure privacy breach. An attacker with one ordinary account can enumerate vehicle identifiers and harvest the personal data and live physical location of the entire customer base. For a Nairobi fintech this creates direct exposure under the Kenya Data Protection Act, 2019, and real-world physical-safety risk, since live location data enables stalking or targeted theft. Confidentiality impact is High; a limited integrity impact is noted because related identity objects can be correlated.

CVSS justification

- **AV:N** — exploitable remotely over the public API.
- **AC:L** — no special conditions; identifiers are sequential/guessable or leaked elsewhere.
- **PR:L** — requires one ordinary authenticated customer account (self-registered).
- **UI:N** — no victim interaction needed.
- **S:U** — impact stays within the vulnerable application's authorisation scope.
- **C:H** — full disclosure of other customers' PII and live location.
- **I:L** — limited; data is primarily read, with correlation of related objects possible.
- **A:N** — no availability impact.

Base score **9.1 (Critical)**. Although PR:L caps the theoretical maximum, the trivial exploitability and whole-population data exposure place this firmly in the Critical band for a fintech.

Steps to reproduce

1. Register two customer accounts (attacker and victim) and authenticate each to obtain a session token.
2. As the victim, view your own vehicle to learn the vehicle identifier format.
3. As the attacker, call the vehicle-location endpoint but supply the *victim's* vehicle identifier in the URL path, presenting only the attacker's own token.
4. Observe that the API returns the victim's record despite no ownership relationship.

Evidence (redacted)

```
GET /identity/api/v2/vehicles/f89b5f21-[REDACTED]/location HTTP/1.1 not distribute
Host: vulnbank.org
Authorization: Bearer [ATTACKER_TOKEN REDACTED]

HTTP/1.1 200 OK
{
  "carId": "f89b5f21-[REDACTED]",
  "vehicleLocation": { "id": 1, "latitude": "[REDACTED]", "longitude": "[REDACTED]" },
  "fullName": "A****",
  "email": "a***@example.com"
}
```

The attacker's token belongs to a different account than the returned record, confirming the authorisation bypass. Coordinates, full name and email are redacted; unredacted capture retained securely.

Remediation

- Enforce a server-side ownership check on every request: confirm the authenticated subject owns the requested `vehicleId` before returning data; otherwise respond 403/404.
- Prefer deriving the object from the session (for example "my vehicle") rather than accepting a client-controlled identifier where possible.
- Use unpredictable, non-enumerable identifiers (UUIDv4) and apply the ownership check regardless.
- Add automated authorisation tests to CI that replay one user's token against another user's objects.

References

OWASP API Security Top 10 (2023) API1 — BOLA · CWE-639 · OWASP WSTG-ATHZ-04 (IDOR).

VB-02 — Broken function-level authorisation lets customers mint coupons and inflate wallet balance

CONFIDENTIAL — Vulnbank Ltd. Security Assessment · Do not distribute

HIGH

Severity	High (CVSS v3.1 base 8.3)
CVSS vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:H/A:L
CWE	CWE-840: Business Logic Errors; CWE-915: Improperly Controlled Modification of Dynamically-Determined Object Attributes (mass assignment)
OWASP	API5:2023 — Broken Function Level Authorization (with API6:2023 — Unrestricted Access to Sensitive Business Flows)
Affected asset	POST /community/api/v2/coupon/new-coupon and POST /workshop/api/shop/apply_coupon
Status	Open — confirmed

Description

Coupon creation is an administrative function, but the `new-coupon` endpoint does not restrict it to privileged roles. A standard customer can submit a coupon definition — choosing the coupon code and the credit amount — and the server stores it as valid. The customer can then redeem that self-created coupon through `apply_coupon`, and the chosen amount is added to their wallet balance. The flaw combines a missing function-level role check with trust in client-supplied object attributes (mass assignment).

Impact

This is a direct financial-integrity and fraud issue. Any customer can increase their own balance to an arbitrary value and spend it through the platform's payment and lending flows, causing direct monetary loss to Vulnbank. Because creation and redemption are both automatable, a single account can scale the fraud, and many accounts can do so in parallel. Integrity impact is High; a limited availability impact is noted because sustained abuse corrupts financial ledgers and reconciliation.

CVSS justification

- **AV:N** — remote over the public API.
- **AC:L** — reliable, repeatable; no special conditions.
- **PR:L** — a single ordinary customer account suffices; no admin role required.
- **UI:N** — no victim interaction.
- **S:U** — contained within the application scope.
- **C:L** — limited data disclosure (coupon/ledger metadata).
- **I:H** — attacker arbitrarily modifies financial balances.
- **A:L** — ledger integrity degradation affects availability of reliable financial data.

Base score **8.3 (High)**. Direct, repeatable manipulation of monetary balances by a low-privileged user is the core driver.

Steps to reproduce

1. Authenticate as a standard customer account.
2. Submit a request to the coupon-creation endpoint specifying a coupon code and credit amount.
3. Observe the server confirms the coupon was stored.

4. Submit the self-created coupon code to the coupon-redemption endpoint.

5. Observe the account's credit balance increases by the chosen amount.

CONFIDENTIAL — Wulmbank Ltd. Security Assessment — Do not distribute

Evidence (redacted)

```
POST /community/api/v2/coupon/new-coupon HTTP/1.1
Authorization: Bearer [CUSTOMER_TOKEN REDACTED]
{ "coupon_code": "[REDACTED]", "amount": "[REDACTED]" }

HTTP/1.1 200 OK
"Coupon Added in database"

--- redemption ---
POST /workshop/api/shop/apply_coupon HTTP/1.1
Authorization: Bearer [CUSTOMER_TOKEN REDACTED]
{ "coupon_code": "[REDACTED]", "amount": "[REDACTED]" }

HTTP/1.1 200 OK
{ "credit": [REDACTED — inflated balance], "message": "Coupon successfully applied!" }
```

A standard account both created and redeemed the coupon; the resulting balance exceeded any legitimately granted credit. Coupon code and amounts redacted.

Remediation

- Restrict coupon creation to authorised administrative roles with a server-side role check; reject standard-user calls with 403.
- Do not accept client-supplied credit amounts; derive coupon value from a server-controlled catalogue.
- Bind each coupon to single use per account, enforce server-side redemption limits, and reconcile balance changes against an auditable ledger.
- Apply explicit allow-lists for mutable fields to prevent mass assignment of sensitive attributes.

References

OWASP API Security Top 10 (2023) API5 — BFLA, API6 — Unrestricted Access to Sensitive Business Flows · CWE-840, CWE-915 · OWASP WSTG-BUSLOGIC-01.

VB-03 — Server-Side Request Forgery reaches internal services and leaks OTP email

CONFIDENTIAL — Vulnbank Ltd. Security Assessment · Do not distribute

MEDIUM

Severity	Medium (CVSS v3.1 base 6.5)
CVSS vector	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
CWE	CWE-918: Server-Side Request Forgery (SSRF)
OWASP	API7:2023 — Server Side Request Forgery
Affected asset	POST /workshop/api/merchant/contact_mechanic
Status	Open — confirmed

Description

The "contact mechanic" workflow accepts a URL that the Vulnbank server then calls on the client's behalf. The supplied URL is neither validated nor restricted to an allow-list, so a customer can point it at an internal-only host. During testing the server was induced to call an internal mail service that is not reachable from the internet, and the internal service's response — including the full contents of a message carrying a one-time password — was returned to the attacker.

Impact

The platform can be used as a proxy into its own trusted internal network, bypassing network boundaries. This enables reconnaissance of internal services, access to internal-only interfaces, and — as demonstrated — disclosure of sensitive internal mail content including OTPs, which can facilitate account-takeover chains. Confidentiality impact is High; no direct integrity or availability impact was demonstrated. Severity is held at Medium because exploitation requires an authenticated account and the demonstrated reach was to a known internal service rather than full internal compromise.

CVSS justification

- **AV:N** — remote over the public API.
- **AC:L** — straightforward to exploit once the parameter is identified.
- **PR:L** — requires an ordinary authenticated account.
- **UI:N** — no victim interaction.
- **S:U** — demonstrated impact remained within the application's authorisation scope.
- **C:H** — disclosure of internal service responses, including OTP email content.
- **I:N / A:N** — no integrity or availability impact demonstrated.

Base score **6.5 (Medium)**. Scope was assessed Unchanged for the demonstrated path; broader internal pivoting would raise this score.

Steps to reproduce

1. Authenticate as a standard customer account.
2. Invoke the contact-mechanic endpoint, supplying a URL that points to an internal service instead of a legitimate mechanic endpoint.
3. Observe that the server fetches the internal URL and returns the internal service's response, including internal mail content.

Evidence (redacted)

```
POST /workshop/api/merchant/contact_mechanic HTTP/1.1
```

```
Authorization: Bearer [CUSTOMER_TOKEN REDACTED]
```

CONFIDENTIAL — Vulnbank Ltd. Security Assessment · Do not distribute

```
{ "mechanic_api": "http://[INTERNAL-HOST REDACTED]/api/v2/messages", ... }
```

```
HTTP/1.1 200 OK
```

```
{ "response_from_mechanic_api": {  
  "items": [ { "Content": { "Headers": { "Subject": ["crAPI OTP"],  
    "To": ["v*****@[REDACTED]"] } },  
    "Body": "Your one time generated otp is: [REDACTED]" } ] } }
```

The returned payload originates from an internal-only service, proving the server made a request to an address the attacker cannot reach directly. Internal hostname, recipient and OTP redacted.

Remediation

- Do not fetch arbitrary user-supplied URLs; use a strict allow-list of permitted mechanic endpoints.
- Validate and canonicalise URLs server-side; reject internal/private and link-local address ranges and non-HTTP(S) schemes, and re-check after DNS resolution to prevent rebinding.
- Isolate internal services on a segmented network and require authentication for internal-to-internal calls so a forged request cannot read sensitive responses.
- Strip or suppress the upstream response body so internal content is never relayed to the client.

References

OWASP API Security Top 10 (2023) API7 — SSRF · CWE-918 · OWASP WSTG-INPV-19.

Prioritised Remediation Roadmap

CONFIDENTIAL — Vulnbank Ltd. Security Assessment · Do not distribute

Actions are sequenced by risk. Immediate items address directly exploitable financial and privacy harm; later items build the systemic controls that prevent recurrence. Suggested owners are indicative and should be confirmed by Vulnbank.

Phase 1 — Immediate (0-7 days)

#	Action	Addresses	Owner
1	Add server-side ownership checks to the vehicle-location endpoint and any endpoint accepting an object identifier; deny cross-account access.	VB-01	API / Backend
2	Disable customer access to coupon creation and reject client-supplied credit amounts; invalidate coupons created during the exposure window and reconcile affected balances.	VB-02	Payments / Backend
3	Restrict the contact-mechanic endpoint to an allow-list of approved URLs; block internal/private address ranges.	VB-03	Backend / Platform

Phase 2 — Short term (1-4 weeks)

#	Action	Addresses	Owner
4	Introduce a centralised authorisation layer enforcing object- and function-level checks consistently across all APIs.	VB-01, VB-02	Architecture
5	Enforce explicit field allow-lists (anti-mass-assignment) and server-controlled coupon catalogues with single-use binding and audit logging.	VB-02	Payments / Backend
6	Segment internal services and require authentication for internal calls; suppress relay of upstream response bodies to clients.	VB-03	Platform / Network

Phase 3 — Medium term (1-3 months)

#	Action	Addresses	Owner
7	Add automated authorisation and business-logic abuse tests to CI, including cross-account token replay.	All	AppSec / QA
8	Adopt non-enumerable identifiers (UUIDv4) and transaction monitoring/alerting on anomalous balance changes.	VB-01, VB-02	Backend / Fraud
9	Establish a recurring security-testing cadence and schedule a retest of all three findings to confirm closure.	All	CISO

Retest. The assessment team recommends a focused retest of VB-01, VB-02 and VB-03 once Phase 1 and Phase 2 are complete, to verify remediation and update each finding's status to Closed.

Appendix A — Ratings, Standards & Redaction

CONFIDENTIAL — Vulnbank Ltd. Security Assessment · Do not distribute

CVSS summary

ID	Severity	Score	Vector
VB-01	Critical	9.1	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N
VB-02	High	8.3	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:H/A:L
VB-03	Medium	6.5	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Standards referenced

- OWASP API Security Top 10 (2023)
- OWASP Web Security Testing Guide (WSTG)
- Common Weakness Enumeration (CWE)
- CVSS v3.1 (FIRST.org)
- Kenya Data Protection Act, 2019 (regulatory context)

Redaction statement

In line with the engagement rules, every sensitive value in this report is redacted: authentication tokens, customer names and email addresses, GPS coordinates, one-time passwords, and internal hostnames. Redacted fields appear as [REDACTED] or partially masked. The assessment team retains the complete, unredacted evidence set securely and will share it with authorised Vulnbank personnel over an encrypted channel on request.

End of report — Vulnbank Web & API Penetration Test, version 1.0, 6 October 2026. CONFIDENTIAL.